

HiveForce Labs

THREAT ADVISORY



ATTACK REPORT

Threat Actors Exploit Microsoft OneNote for Malware Delivery via Phishing Attacks

Date of Publication

March 09, 2023

Admiralty Code

A1

TA Number

TA2023124

Summary

First appeared: Jan 2023

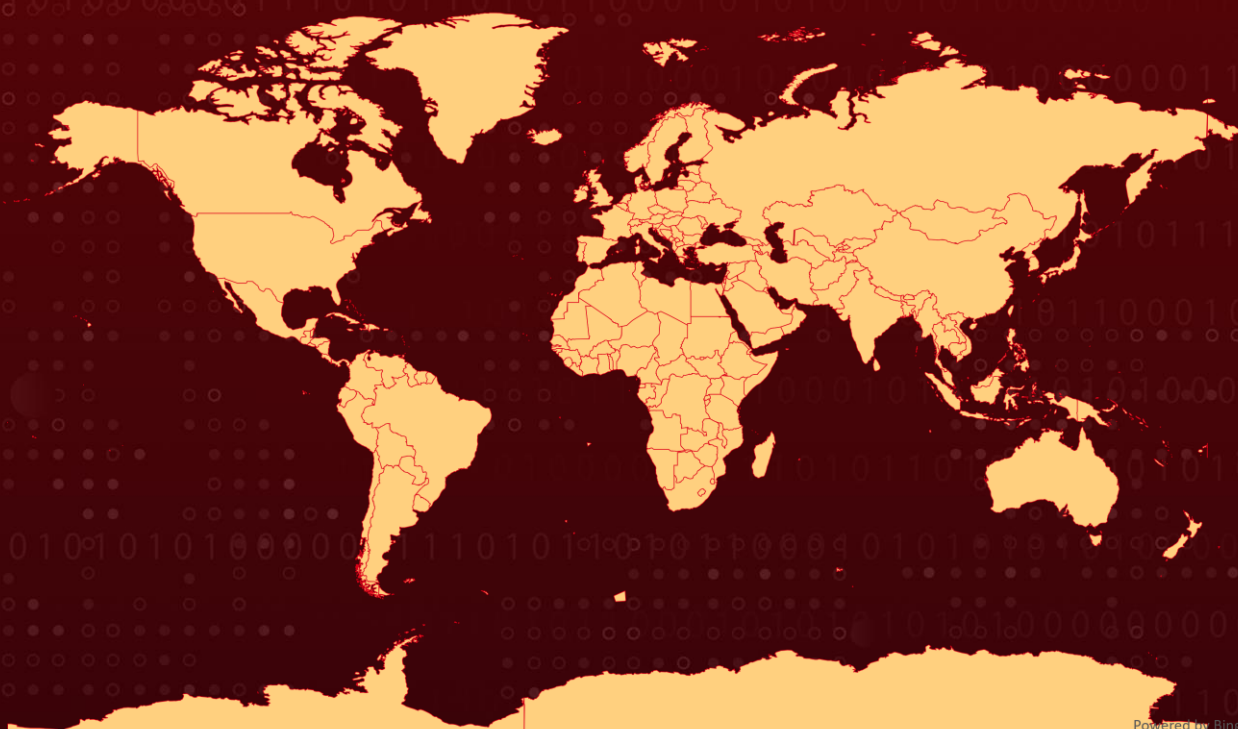
Attack Region: Worldwide

Affected Product: Microsoft OneNote

Malware: AsyncRAT, Formbook

Attack: OneNote attachments are currently being utilized by threat actors in phishing emails, infecting victims with remote access malware capable of installing additional malware, stealing passwords, and even cryptocurrency wallets.

Attack Regions



Powered by Bing

© Australian Bureau of Statistics, GeoNames, Microsoft, Navinfo, OpenStreetMap, TomTom

Attack Details

#1

Cybercriminals are using Microsoft OneNote's ability to embed files to deliver malware to users via social engineering techniques. OneNote allows users to organize information and insert files such as images, documents, and executables. However, attackers can steal data or install ransomware on their systems once users click on the embedded code. A recent campaign involved a malicious OneNote document-delivering Formbook, and there has been a notable spike in emails utilizing malicious OneNote attachments with notorious malware strains also shifting to this delivery mechanism.

#2

The first campaign spotted involved a fake product inquiry, with a OneNote document purporting to be a product inquiry document in PDF format, which, when clicked, loads an embedded executable with a fake inquiry PDF. The script contained PowerShell commands that collected information such as the browser and mail client passwords, images, and videos from desktops and download folders. The stolen data was exfiltrated to a remote FTP server.

#3

The second campaign observed involves a phishing email that pretends to be a shipping notification from DHL. The email contains a OneNote document that, once opened, loads an embedded image file that contains malicious code. This code downloads a DLL file and executes it, leading to the installation of an AsyncRAT on the victim's system. The AsyncRAT then communicates with a command and control server and can be used by the attacker for various malicious purposes.

Recommendations



Security Leaders

Phishing simulations and routine education and awareness training and communications rarely account for MFA fatigue and web browser hygiene. Integrate and communicate all lessons learned.



Security Engineers

- **Uni5 Users:** This is an actionable threat advisory in HivePro Uni5. Prioritize and block all indicators attributed to the threat actors and attacks through your Command Center. Test your controls with Uni5's Breach & Attack Simulation.
- **All Engineers:** Refer to and action upon the 'Potential MITRE ATT&CK TTPs' & 'Indicators of Compromise (IoC)' on the following pages.

Potential MITRE ATT&CK TTPs

<u>TA0002</u> Execution	<u>TA0003</u> Persistence	<u>TA0004</u> Privilege Escalation	<u>TA0005</u> Defense Evasion
<u>TA0006</u> Credential Access	<u>TA0007</u> Discovery	<u>TA0009</u> Collection	<u>TA0011</u> Command and Control
<u>T1027</u> Obfuscated Files or Information	<u>T1113</u> Screen Capture	<u>T1059</u> Command and Scripting Interpreter	<u>T1204</u> User Execution
<u>T1204.002</u> Malicious File	<u>T1059.006</u> Python	<u>T1547</u> Boot or Logon Autostart Execution	<u>T1566</u> Phishing
<u>T1562</u> Impair Defenses	<u>T1574</u> Hijack Execution Flow	<u>T1056</u> Input Capture	<u>T1560</u> Archive Collected Data
<u>T1033</u> System Owner/User Discovery	<u>T1124</u> System Time Discovery	<u>T1125</u> Video Capture	<u>T1555</u> Credentials from Password Stores,
<u>T1059.001</u> Power Shell	<u>T1140</u> Deobfuscate/Decode Files or Information		

Indicators of Compromise (IOCs)

TYPE	VALUE
Domains	372068[.]one 10974543[.]one Evilextractor[.]com
IPV4	198.44.140[.]78 162.247.153[.]39
URL	http://evilextractor.com/wp-content/uploads/2022/12/Python39-322.zip

TYPE	VALUE
SHA1	d2fd7053dc13293a02851cb74837d0788dc1d159 ce7a8a6a8fdc7846b9022a746c39a00a6eb4d19c adb39f9a5f7d82e3886f551418344761f1e668df a2bbfb23b51cb1f2bb213dfe410601bc7fa53875 9ff9c3c674cfd13e2ed6199815d5f1287cd95ff2 7a0ccfb531bdc864a87bd47ce4af91e4243d9c9b 360c70c00d6c2804b3b64f53ef2b68a7e9d79016 1523e0e1f454e480e6e2f8c0282d3fa6ed589059 5a513d230db2bd983575be5902ee2db07dad96c1 2046c77280cb39966b1bbbcab6bdf3d35f5bd72a

References

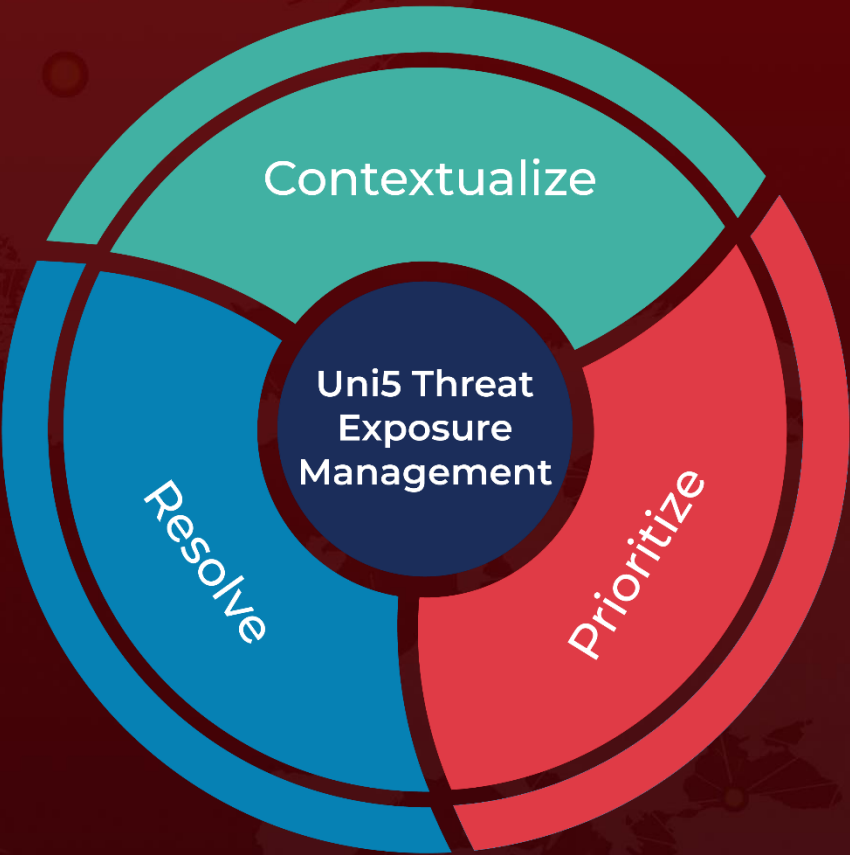
<https://www.trustwave.com/en-us/resources/blogs/spiderlabs-blog/a-noteworthy-threat-how-cybercriminals-are-abusing-onenote-part-1/>

<https://www.trustwave.com/en-us/resources/blogs/spiderlabs-blog/a-noteworthy-threat-how-cybercriminals-are-abusing-onenote-part-2/>

What Next?

At Hive Pro, it is our mission to detect the most likely threats to your organization and to help you prevent them from happening.

Book a free demo with HivePro Uni5: Threat Exposure Management Platform.



REPORT GENERATED ON
March 9, 2023 • 12:10 AM

© 2023 All Rights are Reserved by HivePro



More at www.hivepro.com